

Understanding Privacy Implications of GPTs Variant 1: Comparing GPTs Across Categories in Terms of Private Data Collection

Ivan Jiang Sang Hoon Byeon Sang In Byeon Satya Neriyanuru Jon-Paul Sullivan Arsene Babin
CSE 467: Data & Information Security
Instructor: Rakibul Hasan

Abstract

This project examines privacy concerns in custom GPT ecosystems by comparing how domain-specific GPTs expose data collection pathways, external integrations, and privacy disclosures across multiple categories. Building on Wu et al.'s large-scale analysis of GPT ecosystems, this study uses a smaller controlled design that focuses on category-level comparison through crawler-assisted manifest inspection, Action analysis, and exploratory canary testing instead of full ecosystem-wide replication.

Early in the project, small-scale prompt-based testing was considered as one approach for observing GPT behavior through direct interaction. However, this approach proved limited because smaller-scale testing restricted dataset size and reduced scalability, making broader cross-category comparison difficult. As a result, the methodology shifted toward automated crawler-based manifest collection and expanded canary testing.

Using GPTs collected from multiple public GPT directories, this study combines automated manifest retrieval, category-level Action analysis, canary generation, and comparative privacy categorization across domains such as personal identifiers, health-related information, location, uploaded files, device or usage information, and contextual prompt inputs. Privacy disclosures were also evaluated by comparing observable GPT data practices with available tool-level or platform-level privacy policies.

Initial findings suggest that many sampled GPTs do not expose manifest-defined Actions, while GPTs that do may request or process potentially sensitive information through external parameters, contextual inputs, or third-party integrations. Extended canary testing did not reveal successful canary recovery under the tested conditions. Overall, this study identifies important transparency gaps between GPT data practices and privacy disclosure while highlighting the need for stronger safeguards in domain-specific AI applications.

1. Introduction

Custom GPTs have expanded the capabilities of large language model ecosystems by allowing developers to create assistants tailored to specialized domains such as healthcare, education, travel, finance, legal support, business, news, among others. These systems improve access to domain-specific information through natural language interaction, which is a major advantage. Although this accessibility offers clear benefits, it also creates important privacy concerns. Users may share sensitive information in ordinary prompts without fully recognizing the privacy implications of that disclosure, including medical symptoms, demographic background, emotional distress, location, financial context, or professional information. Because these disclosures often happen in free-form language rather than structured forms, their privacy-risks may be less obvious to users.

privacy-risks in GPT ecosystems are not limited to account creation or visible input fields. GPTs may process information directly from user prompts, infer additional context from language patterns, or rely on external Actions and integrations that send data beyond the immediate conversation. As a result, privacy concerns may exist even when a GPT appears simple or does not clearly advertise external functionality. These concerns are especially important in sensitive areas such as healthcare, finance, and legal assistance, where GPTs may process highly personal or contextual user information.

This project builds on prior work by Wu et al., which examined data collection practices in GPT ecosystems through large-scale crawling of GPT metadata and Action specifications. Their findings showed that GPT Actions can request a wide range of user data while privacy disclosures are often incomplete or unclear. Rather than fully replicating that ecosystem-wide scale, this project explored small-scale prompt-based testing during early planning as one possible way to observe GPT behavior through conversation.

However, this early approach was not used as the pri-

mary final methodology because limited sample size, reduced scalability, and practical category coverage constraints made broader comparison difficult. As a result, the project shifted toward automated crawler-based manifest inspection and expanded canary testing. This methodological shift allowed for broader GPT coverage while maintaining the project’s privacy-focused goals.

Canary testing was included as an exploratory privacy method designed to examine whether unique inserted strings could later become recoverable in separate GPT interactions. Rather than serving as definitive proof of model training behavior, this method provided an additional way to examine possible recoverable retention patterns beyond manifest-visible Action structures.

This revised methodology proved more practical because it allowed category-level comparison through manifest structures, Action prevalence, privacy disclosure review, and exploratory canary testing while improving scalability beyond the project’s earlier limited testing approach. By combining automated GPT collection, category comparison, privacy scoring, and canary analysis, this study adapts key ideas from Wu et al.’s framework into a smaller-scale project while examining transparency gaps and privacy-risks across domain-specific GPT categories.

2. Background and Related Work

Large language model (LLM) ecosystems have increasingly shifted from general-purpose chatbots toward platforms that support specialized applications. In the ChatGPT ecosystem, custom GPTs allow developers to create domain-specific assistants for tasks such as tutoring, travel planning, financial analysis, legal guidance, health support, and news summarization. These systems are useful because they allow users to interact through natural language rather than fixed forms or traditional software interfaces. However, this interaction style also creates privacy concerns because users may disclose sensitive information conversationally and without clearly recognizing that the information could be processed, stored, inferred from, or transmitted to external services.

A major privacy concern in custom GPT ecosystems comes from GPT Actions. Actions allow GPTs to interact with external APIs and services, which can expand functionality but also create additional data exposure risks. Action specifications often describe endpoints, parameters, request bodies, authentication requirements, and response schemas. These technical descriptions can reveal what kinds of user data an Action may request or transmit. For example, an Action that asks for a user’s location, email address, uploaded document, portfolio information, or health-related query may create different privacy-risks depending on the domain and whether that information is necessary for the GPT’s function.

This project builds primarily on the work of Wu et al., who conducted a large-scale investigation of data collection practices in LLM app ecosystems. Their study examined OpenAI’s GPT ecosystem by crawling GPT metadata, analyzing Action specifications, and comparing inferred data collection practices with privacy disclosures. Their findings showed that GPT Actions can collect a wide range of user data and that privacy policies often fail to clearly disclose the full scope of data collection. This prior work motivates our project because it demonstrates that GPT ecosystems can contain meaningful transparency gaps between what tools are capable of collecting and what users are told through privacy disclosures.

While Wu et al. focused on large-scale ecosystem measurement, our project uses a smaller and more controlled design. At the intermediate stage, we tested a healthcare-focused GPT through standardized prompts to observe how it responded to sensitive physical and mental health scenarios. This initial prompt-based testing showed that GPTs can process sensitive information such as symptoms, mental health concerns, medication context, and location even when no external Action is visibly completed. However, this approach was difficult to scale across many categories. After the intermediate phase, we revised the methodology to support broader comparison by using crawler-assisted manifest collection and Action analysis across a wider set of GPT categories.

Our study therefore complements prior work in two ways. First, it compares GPTs across categories rather than only measuring the ecosystem as a whole. This makes it possible to examine whether privacy-risk appears differently in domains such as finance, education, travel, health, legal support, and news. Second, it adds exploratory canary testing as a way to examine whether inserted unique strings could later become recoverable through separate interactions. Although canary testing cannot prove training or retention behavior by itself, it provides an additional privacy-oriented test beyond manifest inspection. Together, these methods allow our project to adapt the ideas of the original study to a smaller, reproducible class-project setting while still examining Action use, privacy disclosures, and cross-category privacy-risk.

3. Methods

This section describes how GPTs were collected, analyzed, scored, and compared across categories. The project began with prompt-based testing during the intermediate stage, but the final methodology shifted toward crawler-assisted manifest analysis and broader category coverage in order to produce a larger and more comparable dataset.

3.1. Preliminary Prompt-Based Testing and Method Revision

During the intermediate stage of the project, we used prompt-based testing as an initial method for studying GPT privacy behavior. This pilot focused on MediGuide, a healthcare-related GPT, and used standardized prompts involving physical symptoms, medication concerns, mental health issues, and location-based healthcare requests. The purpose of this pilot was to observe whether a GPT would ask for additional personal information, infer sensitive context, or attempt to access external services.

This pilot confirmed that direct interaction can reveal privacy-relevant behavior, especially in sensitive domains such as healthcare. However, it also showed that prompt-based testing alone was difficult to scale across a large number of GPTs and categories. After feedback to expand the variety of GPTs analyzed, we revised the final methodology to focus on broader crawler-assisted manifest collection, Action analysis, privacy-risk scoring, privacy disclosure review, and exploratory canary testing. The prompt-based MediGuide test remained useful as an initial validation case, but it was not the primary method used for the final cross-category dataset.

3.2. GPT Collection

GPTs were collected from multiple public GPT directories, including gpts-list.com, topai.tools/ai-assist, and discover-gpts.com. For gpts-list.com, we used a Python crawler with BeautifulSoup to automatically retrieve GPT entries from category pages. For the other sites, GPTs were collected manually because the pages had stronger bot detection or inconsistent link behavior.

Each GPT was recorded with its name, category, ChatGPT link, and gizmo identifier. The gizmo identifier was extracted from the GPT URL, which follows the format `https://chatgpt.com/g/[gizmo]`. These identifiers were then used as inputs to the crawler and manifest retrieval scripts. The collected GPTs were grouped into categories such as business, career, design, development, education, entertainment, finance, games, legal, mindfulness, news, physical health, real estate, travel, and utility.

3.3. Data Taxonomy Construction

We constructed a data taxonomy based on the types of information that GPTs and their Actions may request, process, or infer. The taxonomy was inspired by the original study by Wu et al., but it was adapted for our smaller category-based analysis. The taxonomy includes categories such as chat content, personal identifiers, health-related information, location, uploaded files, device or usage information, financial information, and other contextual prompt inputs.

This taxonomy helped guide privacy-risk scoring by allowing us to classify what kinds of information were im-

plied by Action parameters or GPT functionality. For example, a finance GPT that requests portfolio information may present a different privacy concern than a travel GPT requesting a destination or budget. The taxonomy therefore helped us evaluate not only what data was collected, but also whether that data was appropriate for the GPT's stated purpose.

3.4. Manifest and Action Analysis

The main final analysis relied on GPT manifest inspection. For each collected GPT, we used its gizmo identifier to retrieve the corresponding manifest file through the ChatGPT backend gizmo endpoint. The crawler used an authenticated session token and the GPT gizmo value to request manifest data. The full operational steps for running the crawler are included in the submitted codebase and README rather than in the body of the report.

The manifest files were inspected to determine whether a GPT exposed Actions or external tools. In particular, we checked whether the manifest contained a `paths` field, since this field contains Action specifications and describes available API endpoints. When a manifest did not contain `paths`, the GPT was recorded as having no visible Action APIs. Under the project scoring rules, GPTs without Actions were assigned a privacy-risk score of 0 and their tools/actions field was marked as N/A.

For GPTs that did expose Actions, we examined the Action descriptions, endpoints, parameters, request bodies, response schemas, and authentication requirements. These fields were used to infer what types of user data the Action could request or transmit. We then assigned each GPT a privacy-risk score from 0 to 5 based on the sensitivity of the data involved, whether the data collection appeared necessary for the GPT's function, and whether the Action could expose information to an external service. The reasoning for each nonzero score was recorded in the shared spreadsheet.

3.5. Privacy Disclosure Analysis

For privacy disclosure analysis, we checked whether each GPT or Action provided a tool-specific privacy policy or legal information link. When no GPT-specific policy was available, we recorded the tool as relying on the general platform-level privacy policy. We then compared the specificity of these disclosures with the data types implied by the manifest and Action specifications.

This analysis allowed us to identify whether GPTs with visible Actions or potentially sensitive data practices also provided clear privacy explanations. In many cases, GPTs did not provide detailed tool-specific privacy disclosures, which limited users' ability to understand what data might be collected, transmitted, or retained.

3.6. Canary Testing Procedure

Canary testing was used as an exploratory method for examining possible recoverability of inserted unique strings. For each selected GPT, a reproducible canary string was generated by salting the GPT’s gizmo identifier and hashing it into a base64-like string. This made the canary deterministic for each GPT while still producing a string that would be extremely unlikely to appear naturally.

Because canary insertion and recovery testing were manual, we selected a limited number of GPTs from each category for this part of the study. During insertion, the full canary string was pasted into the GPT using one account, and the insertion date was recorded in the shared spreadsheet. During recovery testing, a different account was used after a waiting period of at least one week.

To test recovery, we used prompts that provided partial snippets of the canary, such as approximately one-third or one-half of the string, and observed whether the system could complete the full original canary. We also tested broader prompts asking ChatGPT to generate base64-like strings without using code. A canary was considered recovered only if the full inserted string was reproduced exactly.

Canary testing was not treated as definitive proof of training, retention, or backend storage. Instead, it was used as an exploratory signal. If a canary were recovered, it would suggest possible recoverability or exposure under the tested conditions, but it would not by itself prove how or why the string became available. In our final results, no successful canary recovery was observed.

3.7. Data Logging and Organization

All collected information was stored in shared spreadsheets and exported as CSV files for analysis. The recorded fields included GPT name, category, canary string, manifest file link, tools/actions and their parameters, privacy-risk score, reasoning, features, canary insertion date, and canary recovery status.

After collection, the CSV files were imported into Python and analyzed with Pandas. Matplotlib was used to generate visualizations showing category-level counts, average privacy-risk scores, percentages of GPTs with measurable tool-based risk, and standard deviations across categories. These measurements were used for descriptive comparison rather than formal statistical significance testing.

3.8. Comparison with the Original Study

This project follows the original study’s general idea of using GPT manifests and Action specifications to infer privacy-relevant data collection. However, our project differs in several important ways. First, the scale is smaller because our dataset was collected manually and through lightweight crawlers rather than through a full ecosystem-wide crawl. Second, our analysis is organized by category,

which allows us to compare domains such as finance, education, travel, health, legal, and news.

Third, we used a 0–5 privacy-risk score to account for both data sensitivity and domain context. This differs from a purely taxonomy-based count of data types because the same data type may have different privacy implications depending on the GPT’s purpose. For example, health information may be more expected in a health-related GPT than in a finance-related GPT. Finally, we included canary insertion and recovery testing as an exploratory extension to examine whether unique strings could become recoverable in later interactions.

Together, these changes allowed the project to adapt the original paper’s ideas to a smaller but more category-focused study. The final methodology emphasizes observable Actions, privacy disclosure gaps, category-level variation, and exploratory canary behavior.

4. Results

This section summarizes the primary findings from GPT collection, crawler-assisted manifest inspection, Action analysis, exploratory canary testing, and privacy review. Across both collected datasets, the project recorded 420 GPT entries across 15 categories, including business, career, design, development, education, entertainment, finance, games, legal, mindfulness, news, physical health, real estate, travel, and utility. For final scoring, entries with missing privacy-risk values were treated as 0 because no visible Action-based privacy-risk was identified for those GPTs under the project framework.

Table 1. Summary of Final GPT Dataset

Dataset Metric	Value
Total GPT entries analyzed	420
Categories represented	15
GPTs assigned risk 0	399
GPTs with nonzero privacy risk	21
Percentage assigned risk 0	95.0%
Percentage with nonzero privacy risk	5.0%
Successful canary recoveries	0

4.1. Dataset Overview and Category Distribution

The dataset shows that most sampled GPTs had no observable Action-based privacy-risk under the project’s scoring framework. Out of 420 total GPT entries, 399 received a privacy-risk score of 0, while only 21 received a nonzero privacy-risk score. This means that approximately 95% of the sampled GPTs did not expose measurable Action-based privacy-risk, while only about 5% showed some form of nonzero privacy concern.

This result suggests that most publicly listed GPTs in the sampled categories did not visibly expose manifest-defined Actions or external tool functionality. In many cases, GPTs appeared to function primarily as prompt-based conversational assistants rather than as systems connected to external APIs or structured data-collection tools. This absence of Actions became one of the central findings of the project.

Nonzero privacy-risk scores were concentrated in a small number of categories. Finance and utility each contained 5 nonzero-risk GPTs, development and education each contained 4, and design, games, and travel each contained 1. Categories such as business, career, entertainment, legal, mindfulness, news, physical health, and real estate did not contain nonzero-risk GPTs under the final scoring framework.

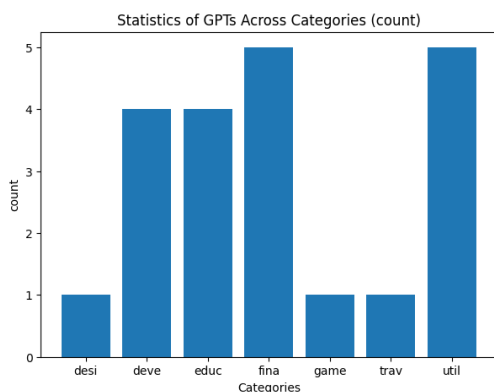


Figure 1. Count of GPTs with nonzero privacy-risk scores across categories.

4.2. Observed Data Requests

Privacy-relevant data patterns differed by category. GPTs without visible manifest-defined Actions were generally assigned privacy-risk scores of 0 because they did not expose structured external data-collection pathways through the manifest. By contrast, GPTs with nonzero privacy-risk scores were more often associated with Action parameters or external capabilities that could involve contextual user inputs, such as financial information, search terms, location-related information, uploaded files, or user preferences.

Although some categories showed isolated higher average privacy-risk scores, these results should be interpreted carefully when the category contained only a small number of nonzero-risk GPTs. Finance appeared to be the strongest overall privacy-risk category because it combined a relatively high number of nonzero-risk GPTs with meaningful data sensitivity. Finance-related GPTs were more likely to involve portfolio information, investment context, market questions, or other financial inputs that could reveal sensitive user behavior.

Overall, the observed data requests suggest that privacy-risk was not evenly distributed across the sampled GPT ecosystem. Instead, measurable Action-based risk was concentrated in a small subset of GPTs and categories.

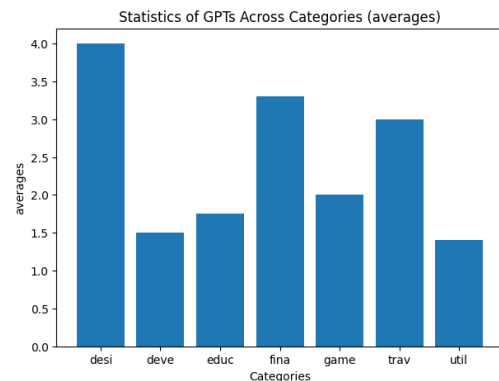


Figure 2. Average privacy-risk score of GPTs with nonzero privacy-risk across categories.

4.3. External Capability Testing

External capability testing focused on whether GPTs exposed manifest-defined Actions, APIs, tools, or other visible external integrations. Under the project framework, GPTs without visible tools were assigned a privacy-risk score of 0. Since 399 out of 420 GPTs received a score of 0, the results show that the majority of sampled GPTs did not visibly expose external Action-based capabilities.

Among the GPTs that did show measurable risk, external capability presence was concentrated in only a few categories. Finance, utility, development, and education contained most of the nonzero-risk cases. Several other categories, including legal, news, physical health, mindfulness, career, business, entertainment, and real estate, showed no measurable nonzero Action-based privacy-risk in the final dataset.

This finding is important because the project initially expected to find more GPTs with Actions. Instead, the results suggest that many public GPTs are not deeply integrated with third-party APIs. The absence of Actions does not mean there are no privacy concerns at all, but it does mean that structured external data transmission was uncommon in the sampled dataset.

4.4. Privacy Policy Observations

Privacy policy analysis compared observable GPT functionality with available GPT-specific, tool-specific, or platform-level privacy disclosures. Across the sampled GPTs, many tools did not provide independent privacy policies or detailed tool-specific explanations. Instead, most appeared to rely on general platform-level privacy policies.

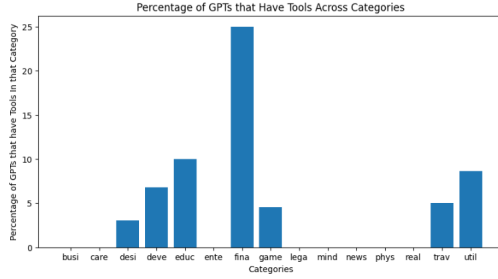


Figure 3. Percentage of GPTs with tools or measurable privacy-risk across categories.

This created a transparency gap. Even when a GPT had visible Actions or appeared capable of processing category-specific user information, the available privacy disclosure often did not clearly explain what data was collected, how it was used, whether it was transmitted externally, or how long it was retained. This issue was especially important for categories such as finance, education, utility, and travel, where even ordinary user inputs may reveal sensitive information.

Overall, the privacy policy results suggest that transparency did not consistently match functionality. GPTs with more specialized purposes or external capabilities did not always provide equally specific privacy disclosures.

4.5. Cross-Category Comparison

Cross-category comparison showed that privacy-risk patterns were uneven across the dataset. Finance emerged as the most analytically significant category because it had one of the highest counts of nonzero-risk GPTs and involved more sensitive data contexts. Utility also contained several nonzero-risk GPTs, though the data sensitivity varied depending on the tool’s function. Development and education showed moderate nonzero-risk presence, while travel, games, and design showed only isolated cases.

The categories with no nonzero-risk GPTs are also important to the overall interpretation. Legal and news GPTs, for example, did not show measurable Action-based risk in the final dataset, despite being domains where users might still share sensitive or personal information conversationally. This reinforces the distinction between Action-based privacy-risk and broader conversational privacy-risk.

These results suggest that category matters, but not always in the expected way. Some sensitive domains did not expose visible Actions, while less obviously sensitive categories occasionally contained tools with external capabilities.

4.6. Canary Testing Results

Canary testing was used as an exploratory method to evaluate whether inserted unique strings could later become

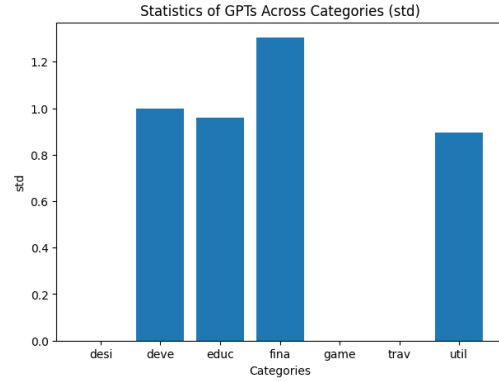


Figure 4. Standard deviation of privacy-risk scores across categories.

recoverable through separate GPT interactions. Each canary was generated deterministically from the GPT’s gizmo identifier and inserted into the corresponding GPT during the collection process. Recovery testing was later performed from a different account using partial-string prompts and broader base64-generation prompts.

This result should not be interpreted as definitive evidence that no retention, storage, or training occurred. The canary test only measures whether the inserted strings could be recovered through the prompts and timing used in this study. If a canary had been recovered, it would have suggested possible recoverability or exposure under the tested conditions, but it would not by itself prove the exact mechanism behind that recovery.

4.7. Alignment with Prior Work

These findings partially align with the original study while also showing important differences. Similar to Wu et al., this project found transparency gaps between GPT functionality and privacy disclosure, especially when GPTs exposed Actions or external capabilities. The project also confirmed that Action specifications are useful for inferring what types of user data a GPT may collect or transmit.

However, the results differ from broader ecosystem-level expectations because most sampled GPTs did not expose visible Actions. This suggests that many public GPTs in the sampled categories function more like prompt-engineered conversational tools than API-integrated applications. Even so, privacy concerns remain relevant because GPTs can still encourage users to disclose sensitive contextual information through ordinary conversation.

Overall, the results show that privacy-risk in GPT ecosystems operates at two levels: technical risk through Actions and external tools, and conversational risk through sensitive user prompts and contextual inference.

5. Limitations

This study has several limitations. First, the dataset is significantly smaller than the large-scale analysis conducted in prior work, and therefore the results should be interpreted as exploratory rather than fully representative of the broader GPT ecosystem. Although the project includes a structured and cross-category sample, it does not capture the full diversity of publicly available GPTs.

Second, many GPTs in the collected dataset did not expose manifest-defined Actions or usable tool specifications. While this finding is itself meaningful, it limited the ability to perform deeper Action-based analysis across categories. As a result, much of the comparison relies on the absence of Actions rather than variation in tool behavior.

Third, the analysis is based on observable behavior, manifest inspection, and limited interaction testing rather than direct access to backend systems. This means that while we can infer how GPTs appear to process and respond to user input, we cannot verify how data is stored, retained, or shared internally. Similarly, canary testing was exploratory and does not provide definitive evidence of data retention or training behavior.

Fourth, the canary testing procedure was exploratory and depended on assumptions about timing, recoverability, and how GPT conversations may or may not be used by the platform. If no canary was recovered, this does not prove that the inserted strings were never stored or processed. It only shows that they were not recoverable under the specific prompts, accounts, and time window used in this project. Similarly, if a canary had been recovered, that result would have required further investigation before drawing conclusions about training, storage, or data sharing mechanisms.

Finally, privacy policy analysis was constrained by the fact that many GPTs did not provide tool-specific privacy disclosures and instead relied on general platform-level policies. This lack of differentiation limited the ability to compare transparency practices across GPTs in a meaningful way.

6. Conclusion

This project examined the privacy implications of custom GPTs by comparing how tools across multiple domains appear to collect, process, and disclose user data. Using crawler-assisted manifest inspection, structured data logging, Action analysis, privacy disclosure review, and exploratory canary testing, the study evaluated privacy-risk across a broad sample of GPT categories.

The central finding is that most sampled GPTs did not expose manifest-defined Actions. Out of 420 GPT entries, only 21 received nonzero privacy-risk scores, meaning that approximately 95% of the sampled GPTs showed no measurable Action-based privacy-risk under the project's

scoring framework. This suggests that many publicly listed GPTs function primarily as conversational or prompt-engineered assistants rather than as tools deeply integrated with external APIs. Among the smaller subset of GPTs with nonzero privacy-risk scores, measurable risk was concentrated in a few categories, especially finance, utility, development, and education, rather than being evenly distributed across the dataset.

At the same time, the absence of Actions does not eliminate privacy concerns. GPTs may still encourage users to disclose sensitive information through ordinary conversation, especially in domains such as healthcare, finance, legal support, education, and travel. The preliminary MediGuide testing showed that prompt-based interaction can involve symptoms, medical history, mental health concerns, and location context even when no live external action is completed. This distinction shows that privacy-risk exists at both the technical level, through Actions and external integrations, and the conversational level, through user prompts and contextual inference.

The project also found that privacy disclosures were often limited. Many GPTs did not provide independent or tool-specific privacy policies and instead relied on general platform-level disclosures. This made it difficult to determine how data was collected, processed, transmitted, or retained for individual GPTs. Canary testing also produced no successful recoveries under the tested conditions, but this result should be interpreted cautiously because it does not definitively prove that no retention or storage occurred.

Overall, the findings suggest that the sampled GPT ecosystem had limited visible Action-based data collection, but also limited transparency. The main privacy concern is therefore not only whether GPTs use external tools, but whether users can clearly understand what information is being processed and how it may be handled. Improving tool-specific privacy disclosures, documenting Action behavior more clearly, and strengthening safeguards for sensitive domains remain important challenges for custom GPT ecosystems.

7. Appendix

7.1. Code and Data

The analysis in this project was conducted by combination of Python-based data collection scripts, manually curated datasets, and spreadsheet-based logging.

Crawler and Data Collection Code

A Python crawler was developed using `requests` and `BeautifulSoup` to collect GPT metadata from public directories such as *gpts-list.com*. The crawler extracted GPT names, category labels, and links to ChatGPT instances. For each GPT, the corresponding gizmo identifier was parsed from the URL and used to retrieve manifest files through

authenticated requests.

The crawler workflow included:

- Sending HTTP requests to category pages
- Parsing HTML content to extract GPT entries
- Extracting GPT links and gizmo identifiers
- Sending authenticated requests to retrieve manifest JSON files
- Storing results in structured CSV format

Manifest Processing and Analysis

Collected manifest files were analyzed using Python (pandas) to identify whether GPTs exposed Actions. Specifically:

- The presence of the `paths` field was used as an indicator of Action availability
- Action parameters, endpoints, and schemas were inspected manually
- Relevant fields were mapped to the project's data taxonomy

Canary Generation Code

Canary strings were generated using a deterministic hashing procedure:

- Input: GPT gizmo identifier
- Process: salted hashing and encoding (base64-like format)
- Output: unique reproducible string per GPT

This ensured a low probability of natural occurrence and consistency across insertion and recovery phases.

Data Storage and Organization

All collected data was stored in shared spreadsheets and exported as CSV files. Key fields included:

- GPT name and category
- Gizmo identifier
- Manifest availability
- Action presence and parameters
- Privacy-risk score (0–5)
- Justification for scoring
- Canary string
- Canary insertion date and recovery status

These datasets were then imported into Python for aggregation and visualization using `pandas` and `matplotlib`.

7.2. Codebook / Themes

This project used a structured data taxonomy to classify potential privacy-relevant information processed by GPTs. The taxonomy was adapted from prior work but modified for category-based analysis.

Primary Data Categories

1. **Chat Content** – Free-form user input and contextual conversational data
2. **Personal Identifiers** – Name, email, phone number, or directly identifying information
3. **Health Information** – Symptoms, diagnoses, medications, and mental health disclosures

4. **Location Data** – GPS location, city, or travel-related inputs
5. **Financial Information** – Portfolio data, investments, or financial context
6. **Uploaded Files** – Documents, images, or other user-provided files
7. **Device / Usage Information** – Metadata such as device or network information
8. **Contextual / Behavioral Data** – Preferences or inferred traits from user input

Privacy-Risk Scoring Framework (0–5)

Each GPT was assigned a score based on observable Action behavior and inferred data sensitivity:

- **0** – No visible Actions; no structured external data collection
- **1–2** – Low sensitivity data or minimal external interaction
- **3–4** – Moderate sensitivity or unclear necessity of data collection
- **5** – High sensitivity data with clear external transmission risk

Scoring considered data sensitivity, relevance to the GPT's function, external API involvement, and potential for third-party data exposure.

7.3. Additional Tables and Figures

Additional materials were created during the analysis but were not included in the main report to keep it concise.

Category-Level Breakdown Table (Extended)

A more detailed table was created showing the total number of GPTs in each category, how many had nonzero privacy risk, the average risk score, and the standard deviation. This table supports the results discussed earlier and gives a clearer breakdown of how privacy risk varies across categories.

Action Presence Distribution

Another visualization was made to show the percentage of GPTs with and without manifest-defined Actions across all categories. This helps reinforce one of the main findings of the project, which is that most GPTs did not expose observable Actions.

Canary Testing Log (Sample)

A portion of the canary testing data was also recorded, including GPT identifiers, generated canary strings, insertion timestamps, recovery attempts, and outcomes. Across all tested cases, no inserted canary strings were successfully recovered.

Example Manifest Snippets

Example GPT manifest files were reviewed to show both cases where no `paths` field was present and cases where API endpoints were defined. These examples helped guide consistent scoring during the analysis.

References

Wu, Y., Jaff, E., Yang, K., Zhang, N., and Iqbal, U. (2025). An In-Depth Investigation of Data Collection in LLM App Ecosystems.

<https://dl.acm.org/doi/epdf/10.1145/3730567.3732912>

Andrew Steele. (2023). How to Hack ChatGPT: The 'Grandma Hack.'

<https://youtu.be/1g-TsTvUkA4?si=9tr0aLHhaFPxPsPt>

OpenAI. (2024). OpenAI Privacy Policy.

<https://openai.com/policies/privacy-policy>